A04 - Cryptographic Failures

➡ **Problem:** Weak or improperly implemented cryptography exposes sensitive data

◉ **Impact:** Data disclosure, credential theft, or compromised communications

Common vulnerabilities:

- **Insufficient Transport protection:** sensitive data transmitted without authentication and encryption
- **Password storage:** weak or unsalted password hashing

Preventing Cryptographic Failures

- **Encrypt HTTP session:** Protect sensitive data at rest and in transit (TLS 1.2+, preferably TLS 1.3)

- **Enforce secure communication:**
  - Valid certificates
  - Use `secure` cookie flag with authentication cookie
  - Enable HTTP Strict Transport Security (HSTS)

- **Hash passwords securely:** Use salted, slow password hashing (Argon2id, scrypt)